MDM: Financial Technology

Module No. 5: Risks, Security and Regulations in Financial Technology

Q1. Explain the major cybersecurity challenges faced by digital financial services.

Digital finance makes payments quick and convenient, but it also creates opportunities for criminals to attack accounts, applications and customer information. Cybersecurity means protecting financial systems and data from unauthorised access, damage or theft.

Major challenges

1. Phishing and social engineering: Fraudsters send fake bank messages or call pretending to be bank staff to trick people into revealing passwords, PINs or OTPs.
2. Malware and ransomware: Harmful software may steal banking details, monitor activity or lock important systems.
3. Identity and credential theft: Stolen passwords, card details or identity information can be used to access accounts.
4. Data breaches: Weak security may expose customers' personal and financial information.
5. Service disruption: Attacks or technical failures can make payment apps and banking services unavailable.

Example: A customer receives a fake message saying that their bank account will be blocked. Clicking the link may take them to a look-alike website that steals their login details. Awareness, secure technology and quick reporting help reduce such risks.

Q2. What is financial fraud? Explain any four common types of financial fraud with examples.

Financial fraud is the intentional use of deception to steal money, obtain financial benefits or misuse another person's financial information. In digital finance, fraudsters often exploit trust, urgency or lack of awareness.

Common types

- Phishing: A fake email or website asks a customer to enter banking credentials.
- UPI or QR-code fraud: A fraudster asks a person to scan a QR code or approve a collect request under a false pretext. A QR code or request should never be approved without understanding the transaction.
- Card fraud: Stolen card details are used to make unauthorised purchases.
- Impersonation fraud: Someone pretends to be a bank officer, police official, delivery agent or customer-care representative to pressure a victim into sharing sensitive information.

Example: A caller claims to be from customer support and asks for an OTP to "reverse" a payment. Sharing the OTP can allow an unauthorised transaction. Genuine support staff should not ask customers to disclose OTPs or PINs.

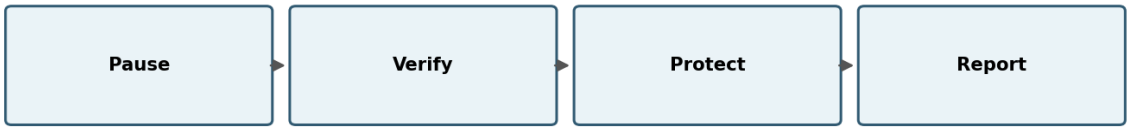
Q3. Suggest practical techniques to prevent financial fraud in digital transactions.

Fraud prevention works best when customers, banks and payment platforms all play their part. Simple habits can prevent many avoidable losses.

Prevention techniques

- Never share a PIN, password, CVV or OTP with anyone, even if the person claims to represent a bank.
- Use only official banking apps and websites; check the web address before signing in.
- Verify the receiver's name and amount before confirming a payment.
- Use strong, unique passwords and multi-factor authentication wherever available.
- Enable transaction alerts and review account statements regularly.
- Avoid banking over public Wi-Fi and keep the phone, browser and banking app updated.
- If a transaction looks suspicious, contact the bank through an official channel immediately and report it promptly.

A simple fraud-prevention routine



Remember: A genuine payment generally requires the payer to authorise it. Do not enter a UPI PIN simply to receive money.

Q4. Explain data privacy and data security in financial systems. Differentiate between them.

Financial institutions handle sensitive information such as names, account details, transaction histories, identity documents and credit records. Data privacy concerns how this information is collected and used; data security concerns how it is protected from unauthorised access, loss or alteration.

Basis	Data Privacy	Data Security
Main concern	Whether data is collected and used fairly and for a clear purpose.	How data is protected against theft, loss or unauthorised access.
Key question	"Should we collect or use this data?"	"How do we keep this data safe?"
Methods	Consent where required, purpose limitation, data minimisation and clear notices.	Encryption, access controls, secure backups, authentication and monitoring.

Example	Collecting only the details needed to process a loan application.	Encrypting the loan applicant's documents and restricting staff access.

Both are necessary. A system can be secure but still misuse data or have a good privacy policy but weak technical protection.

Q5. Explain the important methods used to secure digital financial transactions.

A secure transaction checks that the right customer is acting, protects information while it moves between systems and detects unusual activity.

Important security methods

- Encryption: Converts information into a protected form so unauthorised people cannot easily read it.
- Multi-factor authentication (MFA): Uses more than one proof of identity, such as a password and an approved second factor.
- Tokenisation: Replaces sensitive payment-card information with a token for certain transactions, reducing exposure of the original details.
- Access control: Gives employees and systems only the permissions needed for their work.
- Fraud monitoring: Uses alerts, rules and analytics to flag unusual transaction patterns for review.
- Secure backups and updates: Help restore services after an incident and fix known software weaknesses.

Example: If a card is suddenly used for several high-value purchases in a new location, a monitoring system may flag the activity and the bank may ask the customer to verify it.

Q6. What is multi-factor authentication? Explain how it improves financial security.

Multi-factor authentication (MFA) verifies a user through two or more different types of evidence. These factors commonly include something the user knows, something the user has, or something the user is.

How it works

- The customer enters a username and password.
- The system asks for another factor, such as an approved authenticator prompt, one-time code or biometric check.
- Access is granted only after the required checks are completed.

MFA makes account takeover harder because a stolen password alone may not be enough. For example, if a criminal learns a customer's password, the additional factor may prevent login. Customers must still be alert: they should never disclose OTPs or approve unexpected login requests.

Q7. Differentiate between Tokenization and Encryption.

Tokenization and encryption are both used to protect sensitive information, but they work differently.

Basis	Tokenization	Encryption
Basic idea	Replaces sensitive information with a token.	Converts readable data into an unreadable encrypted form.
Mechanism	Uses a token linked to the original information through a secure system.	Uses a cryptographic algorithm and key.
Recovery	Original data is retrieved through the authorized token system or vault.	Original data is recovered using the correct decryption key.
Data format	The token may be designed to fit a required format.	Encrypted data may look different from the original and may change in size.
Typical use	Payment-card numbers and other structured sensitive data.	Files, databases, stored records and communications.
Example	Replacing a card number with TK_7392_XY81.	Encrypting a database so that its contents cannot be read without the appropriate key.

Q8. What is regulatory compliance in Financial Technology? Why is it important?

Regulatory compliance means following the laws, rules, directions and standards that apply to a financial service. FinTech companies and banks must understand which requirements apply to their products, operations, customers and data.

- Customer protection: Helps ensure customers are treated fairly and receive clear information.
- Prevention of financial crime: KYC and anti-money-laundering controls help identify customers and detect suspicious activity.
- Data protection: Supports responsible collection, processing, storage and sharing of personal information.
- Trust and stability: Compliance reduces operational and legal risks and strengthens confidence in digital finance.
- Accountability: Records, audits and complaint-handling processes help show whether an institution is following the rules.

Example: A regulated financial service may need to verify a customer's identity before providing certain services and maintain appropriate records. The exact requirements depend on the service and applicable rules.

Q9. Explain the role of the Reserve Bank of India (RBI) in regulating digital financial services.

The Reserve Bank of India is India's central bank and plays a key role in regulating and supervising banks and various payment systems within its legal authority. Its directions and frameworks help make financial services safer and more reliable.

- Regulation and supervision: Issues applicable directions for regulated banks and other entities under its remit.
- Payment-system oversight: Supports the safe and efficient functioning of payment systems and payment service providers within its jurisdiction.

- Customer protection: Sets or supports requirements relating to customer service, grievance handling and authorised digital transactions.
- Risk management: Requires relevant regulated entities to manage operational, technology and security risks.
- Financial integrity: KYC and anti-money-laundering requirements help reduce misuse of the financial system.

Example: A regulated entity must follow the RBI directions that apply to its activities and maintain suitable controls. The RBI's role does not mean that every FinTech company is regulated in the same way; the applicable regulator and rules depend on the activity.

Q10. What are KYC and AML? Explain their importance in preventing financial crime.

KYC stands for Know Your Customer. It is the process of verifying a customer's identity and relevant details. AML stands for Anti-Money Laundering, which refers to measures designed to prevent criminals from making illegally obtained money appear legitimate.

Importance of KYC and AML

- Identity verification makes it harder to open or operate accounts using false identities.
- Risk checks help financial institutions understand whether a customer or transaction requires closer review.
- Transaction monitoring can identify unusual patterns, such as activity inconsistent with the expected use of an account.
- Record keeping and reporting, where required, help competent authorities investigate suspected financial crime.
- These controls protect customers and support confidence in the financial system.

Example: If an account receives many unusual transfers and quickly sends the funds elsewhere, the institution may review the activity under its applicable monitoring procedures. An alert is not proof of wrongdoing; it requires appropriate assessment.

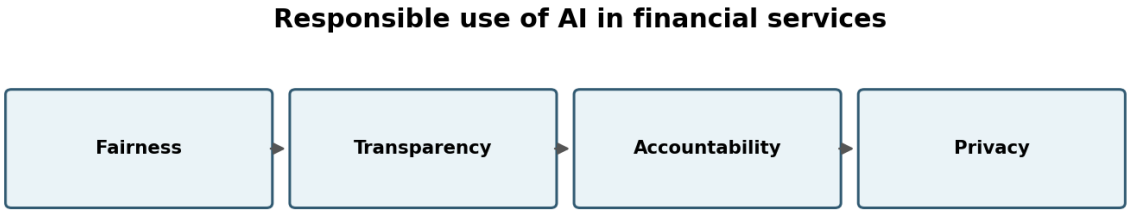
Q11. Discuss the major ethical issues in the use of Financial Technology.

FinTech can improve access and speed, but technology should be used in a way that respects people and avoids unfair harm. Ethical practice goes beyond simply meeting minimum legal requirements.

Major ethical issues

- Privacy: Collecting more personal data than necessary or using it without a clear, appropriate purpose.
- Bias and discrimination: Automated credit or insurance decisions may unfairly disadvantage groups if data or models are biased.
- Lack of transparency: Customers may not understand fees, risks or why an automated decision was made.

- Manipulative design: Apps may pressure users into borrowing, investing or sharing data without a fair understanding of consequences.
- Accountability: Institutions must take responsibility for errors, complaints, security failures and harmful outcomes.



Example: A loan-scoring model should be tested for unfair patterns and should have a process for reviewing disputed decisions. Automation should support sound judgement, not remove responsibility.

Q12. Explain responsible use of Artificial Intelligence (AI) in financial services.

AI can help financial institutions detect fraud, answer customer questions, assess risk and identify unusual transactions. Responsible use means applying these tools carefully, testing them and keeping humans accountable for important decisions.

Principles for responsible AI

- Fairness: Test whether decisions produce unjustified differences between customer groups.
- Transparency: Explain decisions in clear language as far as practical, especially when customers are affected.
- Privacy and security: Use data lawfully and protect it from unauthorised access.
- Accuracy and monitoring: Test models before use and monitor performance as customer behaviour and fraud patterns change.
- Human oversight: Provide a way for staff to review important or disputed decisions.
- Accountability: Define who is responsible when the system makes an error and how the error will be corrected.

Example: An AI system may flag a transaction as suspicious, but a bank should have suitable review and appeal processes rather than treating every automated alert as conclusive proof of fraud.

Q13. What is the importance of customer consent, transparency and grievance redressal in digital finance?

Customers should be able to understand what a financial product does, what it costs, what information is used and how to seek help if something goes wrong. These practices build trust and help prevent avoidable disputes.

- Consent and choice: Where consent is required, it should be meaningful and informed—not hidden in confusing wording.

- Transparent terms: Fees, interest, risks, repayment conditions and relevant data practices should be communicated clearly.
- Accessible complaints process: Customers should know how to raise a complaint and receive a reference or acknowledgement.
- Timely resolution: Institutions should investigate fairly and communicate the outcome within the applicable timelines.
- Protection from misleading practices: Marketing and app design should not create false promises or conceal important conditions.

Example: Before accepting a digital loan, a customer should be able to understand the interest, fees, repayment schedule and consequences of missed payments. If a charge appears incorrect, the customer should have a clear route to dispute it.

Q14. Explain the compliance process that a FinTech organisation can follow to manage regulatory and security risks.

Compliance is not a one-time checklist. A FinTech organisation should regularly identify its obligations, build controls, check whether they work and correct gaps.

Identify applicable regulations

↓

Prepare policies and controls

↓

Verify customers and transactions

↓

Protect data and systems

↓

Maintain records

↓

Conduct audits and testing

↓

Report incidents and violations

↓

Update controls when rules change

- Identify applicable requirements based on the product, customer, data handled and type of financial activity.
- Assign responsibility to appropriate teams and document policies and procedures.
- Build controls such as identity checks, access restrictions, secure development, data protection and complaint handling.
- Train employees and communicate clear responsibilities to third-party vendors.
- Monitor transactions, incidents and control performance; conduct reviews or audits at suitable intervals.
- Record incidents, correct weaknesses and update controls when risks or requirements change.

Example: Before launching a new payment feature, a company should assess security and compliance risks, test the feature, inform customers clearly and establish a process for handling complaints and incidents.

Q15. What is an RBI Regulatory Sandbox? Explain its purpose and working with a suitable diagram.

A Regulatory Sandbox is a controlled environment in which selected FinTech products and services can be tested with a limited number of users under regulatory supervision before being introduced on a larger scale. The RBI's regulatory sandbox framework supports innovation while allowing potential risks to be assessed.

Purpose of a Regulatory Sandbox

1. Customer protection: Helps identify risks that could harm customers before a product reaches the wider public.
2. Controlled testing: Allows a new financial product to be tested under defined conditions.
3. Encourages innovation: Gives FinTech companies an opportunity to experiment with new technologies.
4. Risk assessment: Helps identify security, operational and compliance-related weaknesses.
5. Improvement before launch: Feedback from testing helps companies improve the product.

Example: A FinTech company develops an AI-based lending application. Instead of immediately releasing it to millions of customers, it tests the application with a limited group, evaluates its performance and identifies risks before considering a wider launch. Thus, a regulatory sandbox supports innovation while encouraging customer protection and responsible financial technology.

Q16. Explain the CIA Triad and its importance in FinTech security.

The CIA Triad is a basic information-security model consisting of three principles: Confidentiality, Integrity and Availability. These principles help financial institutions protect data and maintain reliable digital services.



The three principles work together to secure financial information and services.

1. Confidentiality: Confidentiality means that information should be accessible only to authorized people. Example: One banking customer must not be able to view another customer's account balance or transaction history. Security measures: Encryption, passwords, access controls and multi-factor authentication.

2. Integrity: Integrity means that information must remain accurate and should not be changed without authorization. Example: A payment of ₹1,000 must not be altered to ₹10,000 while being transmitted between systems. Security measures: Digital signatures, transaction validation, access controls and audit logs.

3. Availability: Availability means that systems and services should be accessible to authorized users when required. Example: A UPI application should remain available during peak transaction hours so that customers can make payments. Security measures: Backups, disaster recovery, system redundancy and protection against service-disruption attacks.

Thus, Confidentiality protects information from unauthorized viewing, integrity prevents unauthorized changes, and availability ensures access to services. All three are essential for secure and dependable digital finance.

Q17. Differentiate between Authentication and Authorization with examples.

Authentication verifies the identity of a user, whereas authorization determines what an authenticated user is permitted to access or perform.

Basis	Authentication	Authorization
Meaning	Verifies who the user is.	Determines what the user can do.
Main question	Who are you?	What are you allowed to do?
When it occurs	Generally occurs before authorization.	Generally follows successful authentication.
Methods	Password, OTP, fingerprint, facial recognition.	Access permissions, user roles and access-control rules.
Example	Logging into a mobile banking app using a password and approved verification factor.	Allowing a customer to view their own account but not another customer's account.

Q. 18 Discuss the regulatory challenges faced by Financial Technology companies.

Financial Technology (FinTech) companies operate at the intersection of finance and technology, providing innovative services such as digital payments, automated lending, neo-banking, InsurTech, and algorithmic wealth management.

Key Regulatory Challenges Faced by FinTech Companies

I. Fragmented Overlap and Multiple Regulators

- **Issue:** FinTech companies often operate across multiple verticals (e.g., a payment app offering mutual funds and micro-insurance).
- **Challenge:** In many jurisdictions (like India), different regulatory bodies govern distinct domains—the RBI for banking/payments, SEBI for capital markets, and IRDAI for insurance. Navigating overlapping rules, multiple licensing regimes, and conflicting jurisdictional boundaries increases legal complexity and compliance costs.

II. Regulatory Lag vs. Technological Pace

- **Issue:** Technology evolves exponentially (e.g., AI algorithms, decentralised finance, smart contracts), while legislation develops incrementally.
- **Challenge:** FinTech firms frequently operate in legal "grey zones" where specific regulations do not yet exist. When regulators eventually introduce new rules, FinTechs face sudden structural changes or product shutdowns (e.g., restrictions on prepaid payment instruments or peer-to-peer lending limits).

III. Data Privacy, Protection, and Localization Laws

- **Issue:** FinTech business models rely heavily on collecting, processing, and analyzing massive amounts of personal financial data.
- **Challenge:** Stricter privacy laws (e.g., India's DPDP Act, EU's GDPR) mandate explicit consent architecture, strict purpose limitation, and data localization (storing data domestically). Meeting these requirements demands expensive cloud migration and ongoing compliance auditing.

IV. Strict Anti-Money Laundering (AML) and KYC Norms

- **Issue:** Financial systems must prevent money laundering, terrorist financing, and identity fraud.
- **Challenge:** Traditional Know Your Customer (KYC) procedures are paper-heavy, but switching to Video-KYC or e-KYC requires continuous adherence to evolving identity verification laws. Remote onboarding makes platforms vulnerable to deepfakes and fraud, exposing FinTechs to severe penalties if compliance checks fail.

V. Stringent Digital Lending & Outsourcing Mandates

- **Issue:** Unlicensed digital lending apps previously engaged in predatory interest rates, hidden charges, and unethical recovery practices.
- **Challenge:** Regulators now enforce strict rules:
    - Direct Disbursement: Money must flow directly between the regulated bank/NBFC and the borrower, without passing through the FinTech platform's pool account.
    - Transparency: Compulsory issuance of Key Fact Statements (KFS) detailing the Annual Percentage Rate (APR).
    - Data Access Restrictions: Prohibitions on accessing phone contacts, gallery, or media.